

SUSPICIOUS LOGIN INVESTIGATION MINI- REPORT

Table of Contents

1. Executive Summary

2. Scope and Objectives
3. Investigation Methodology
4. Baseline Analysis: Normal User Behavior
5. Anomaly Identification
6. Detailed Attack Timeline
7. Threat Intelligence Enrichment
8. Initial Access Hypothesis
9. Post-Compromise Activity Analysis
10. Key Findings
11. Indicators of Compromise (IoCs)
12. MITRE ATT&CK Framework Mapping
13. Recommended Response Actions
14. Communication Strategy
15. Conclusion and Recommendations

Executive Summary

This report presents the findings of a security investigation conducted by the Security Operations Team (SOC) at **CyberInfiniti Ltd** following the detection of suspicious sign-in activity associated with the user account of **Erwin Smith**, a Financial Analyst within the organization. The investigation was initiated after anomalous login patterns were identified through routine monitoring of authentication logs within Splunk Cloud.

The analysis covered a review of sign-in logs and user activity logs from **25 July to 01 August 2023**. A total of 25 sign-in events and 55 activity events were examined. The investigation followed a structured methodology involving baseline establishment, anomaly detection, threat intelligence enrichment, and activity correlation.

The investigation confirmed that the user account was compromised. Multiple failed authentication attempts from foreign IP addresses were observed, followed by successful logins from previously unrecognized locations, specifically Bulgaria and China. Post-authentication analysis revealed that the attacker accessed and downloaded sensitive organizational data, including a payroll file and an internal vulnerability report. This constitutes a **high-severity security incident** involving confirmed **data exfiltration**.

Immediate containment measures have been recommended, including password reset, session termination, IP blocking, and enforcement of Multi-Factor Authentication (MFA). A full data exposure impact assessment is required to determine regulatory reporting obligations under GDPR.

Scope and Objectives

1.1 Scope

This investigation covers the analysis of sign-in and activity logs for the user account of Erwin Smith over the period of 25 July to 01 August 2023. The data was ingested and analyzed using Splunk Cloud, the organization's Security Information and Event Management (SIEM) platform.

CyberInfiniti Ltd conducted this investigation on behalf of the organization.

The following Splunk query was used as the primary search:

```
source="signin_logs_erwin.csv"  
host="si-i-0265a32aecf69c9f5.prd-p-klvjm.splunkcloud.com" sourcetype="csv"
```

The logs under review included:

- **signin_logs_erwin.csv** — 25 authentication events capturing login attempts, timestamps, IP addresses, applications, and status (Success/Failure)
- **activity_logs_erwin.csv** — 55 user activity events capturing file access, application usage, and resource interactions

1.2 Objectives

The primary objectives of this investigation were to:

- Determine whether the suspicious sign-in activity represents a legitimate or malicious event
- Identify which IP addresses are legitimate and which are potentially malicious
- Assess whether any unauthorized access to organizational data occurred
- Identify Indicators of Compromise (IoCs) for threat mitigation
- Recommend appropriate response actions and communication strategies
- Document all investigation steps, evidence, and findings for audit purposes

Investigation Methodology

The investigation followed a structured, evidence-based approach consistent with industry-standard incident response frameworks.

Phase 1: Log Ingestion and Initial Review

Sign-in and activity logs were ingested into Splunk Cloud for centralized analysis. Key fields including IP addresses, timestamps, application names, authentication status, and resources accessed were extracted. An initial review of 25 sign-in events and 55 activity events was conducted.

Phase 2: Baseline Establishment

A behavioral baseline was established by identifying the user's normal login patterns, including consistent IP address, typical login times, frequently used applications, and expected geographic location.

Phase 3: Anomaly Detection

All events deviating from the established baseline were flagged. This included logins from unfamiliar IP addresses, failed authentication attempts, access from foreign locations, and unusual application access patterns.

Phase 4: Threat Intelligence Enrichment

Each suspicious IP address was cross-referenced against external threat intelligence platforms, including Virus Total and open-source intelligence feeds.

Phase 5: Activity Correlation

Sign-in logs were correlated with activity logs to determine what actions were performed after each successful authentication, establishing whether the compromise resulted in data access or exfiltration.

Phase 6: Impact Assessment and Reporting

Files accessed and downloaded by suspicious IP addresses were catalogued and assessed for sensitivity. Findings were compiled into this report with recommended response actions.

Baseline Analysis: Normal User Behavior

Establishing a behavioral baseline is a critical first step. By understanding normal user behavior, deviations can be identified with confidence.

Analysis revealed that the user consistently authenticated from **143.58.226.102**, geolocating to the **United Kingdom** and associated with the network **UK-BCUBE**. All authentication events from this IP were successful, spanning the full investigation period.

The user's typical activity included regular use of Microsoft productivity applications (Teams, Outlook, Excel, Word, PowerPoint, SharePoint, OneDrive). Login times were consistent with standard UK business hours (approximately 08:00 to 17:30). Activity logs confirmed routine document editing, email communication, conference calls, and file access on SharePoint.

Table 1: Baseline User Profile

Attribute	Details
Legitimate IP	143.58.226.102
Location	United Kingdom
Network	UK-BCUBE
Virus Total Score	0/95 (Clean)

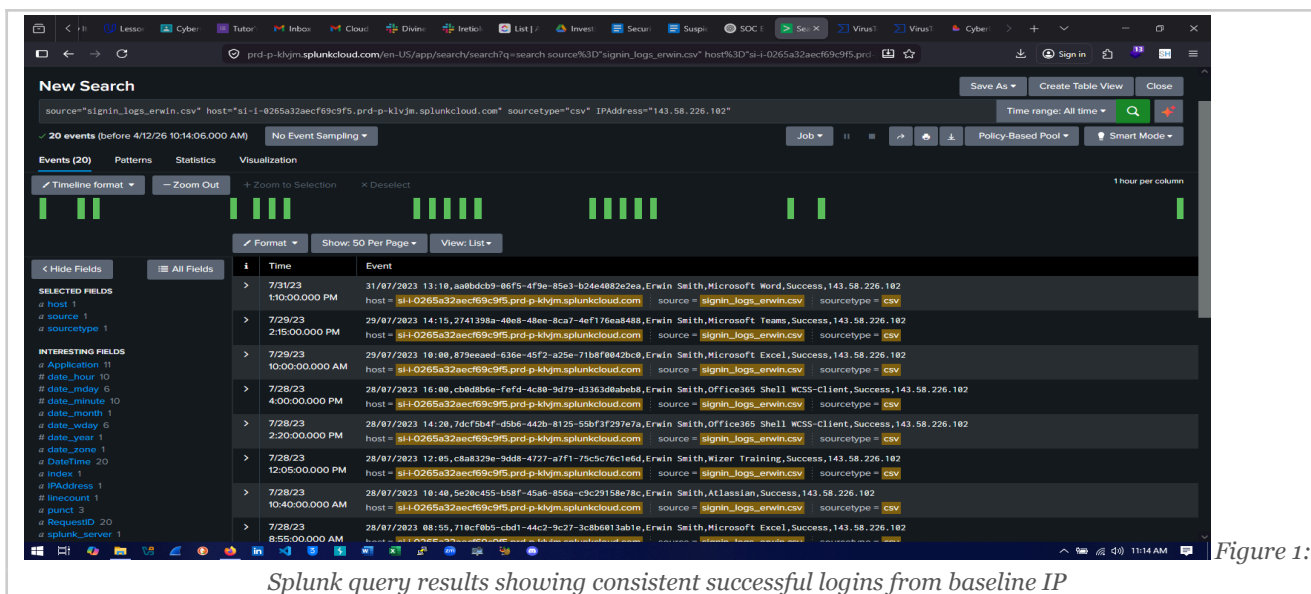


Figure 1:

Splunk query results showing consistent successful logins from baseline IP

5. Anomaly Identification

With the baseline established, the investigation focused on identifying deviations. Three foreign IP addresses were identified in the sign-in logs, entirely inconsistent with the user's known UK location.

1.3 Suspicious IP Address: 79.124.60.6 (Bulgaria)

This IP appeared in three sign-in events and represents the most critical anomaly. The login pattern shows a classic **failed-to-successful** progression, a hallmark of brute-force or credential stuffing attacks:

- **30 July 2023, 10:45** — Failed login (Microsoft Exchange)
- **31 July 2023, 08:20** — Failed login (Microsoft Outlook)
- **31 July 2023, 13:11** — **Successful login** (Microsoft SharePoint)

The transition from repeated failures to success is highly indicative of a persistent attacker. Once authenticated, the attacker gained access to SharePoint, providing direct access to organizational documents and data.

1.4 Suspicious IP Address: 150.158.77.170 (China)

This IP appeared in a single sign-in event on **31 July 2023 at 09:50**, resulting in a successful authentication to Microsoft Online. It geolocates to China and is associated with **Tencent (AS45090)**. The IP was flagged by **three security vendors** on Virus Total for phishing-related activity. No post-authentication activity was observed from this IP.

1.5 Suspicious IP Address: 124.120.140.202 (Thailand)

This IP appeared in a single **failed** login attempt on **31 July 2023 at 11:30**, targeting Azure CLI. It geolocates to Thailand (TRUEBB-NET ISP). VirusTotal returned a clean score (0/95). The targeting of Azure CLI suggests an attacker with knowledge of cloud infrastructure.

Table 2: Summary of Anomalous IP Addresses

IP Address	Location	Status Pattern	Application	Risk
------------	----------	----------------	-------------	------

79.124.60.6	Bulgaria	Failed > Failed > Success	Exchange, Outlook, SharePoint	CRITICAL
150.158.77.170	China	Success	Microsoft Online	HIGH
124.120.140.202	Thailand	Failed	Azure CLI	LOW

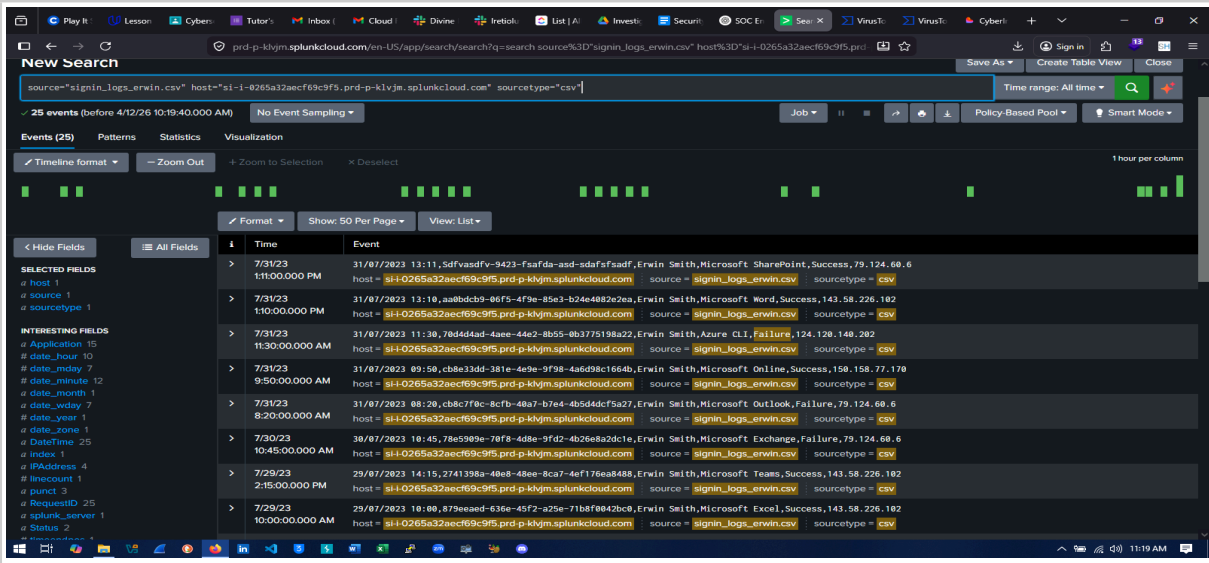


Figure 2: Splunk results highlighting failed and successful logins from foreign IP addresses

Detailed Attack Timeline

The following timeline reconstructs the complete sequence of events from initial reconnaissance through to confirmed data exfiltration.

Table 3: Complete Attack Timeline

Date / Time	Source	Event Description	IP Address	Status
25–29 Jul	Sign-in	Normal activity from UK IP	143.58.226.102 (UK)	Normal
30 Jul 10:45	Sign-in	Failed login — Exchange	79.124.60.6 (Bulgaria)	FAILED
31 Jul 08:20	Sign-in	Failed login — Outlook	79.124.60.6 (Bulgaria)	FAILED
31 Jul 09:50	Sign-in	Successful login — MS Online	150.158.77.170 (China)	SUCCESS
31 Jul 10:20	Activity	File accessed: vulnerability_report_J	79.124.60.6 (Bulgaria)	ACCESS
31 Jul 11:30	Sign-in	Failed login — Azure CLI	124.120.140.202 (Thailand)	FAILED
31 Jul 13:10	Sign-in	Normal login — Word	143.58.226.102 (UK)	Normal
31 Jul 13:11	Sign-in	Successful login — SharePoint	79.124.60.6 (Bulgaria)	SUCCESS
31 Jul 17:10	Activity	File downloaded: updated_payroll.xlsx	79.124.60.6 (Bulgaria)	EXFIL
31 Jul 17:15	Activity	Normal editing — Report7.docx	143.58.226.102 (UK)	Normal

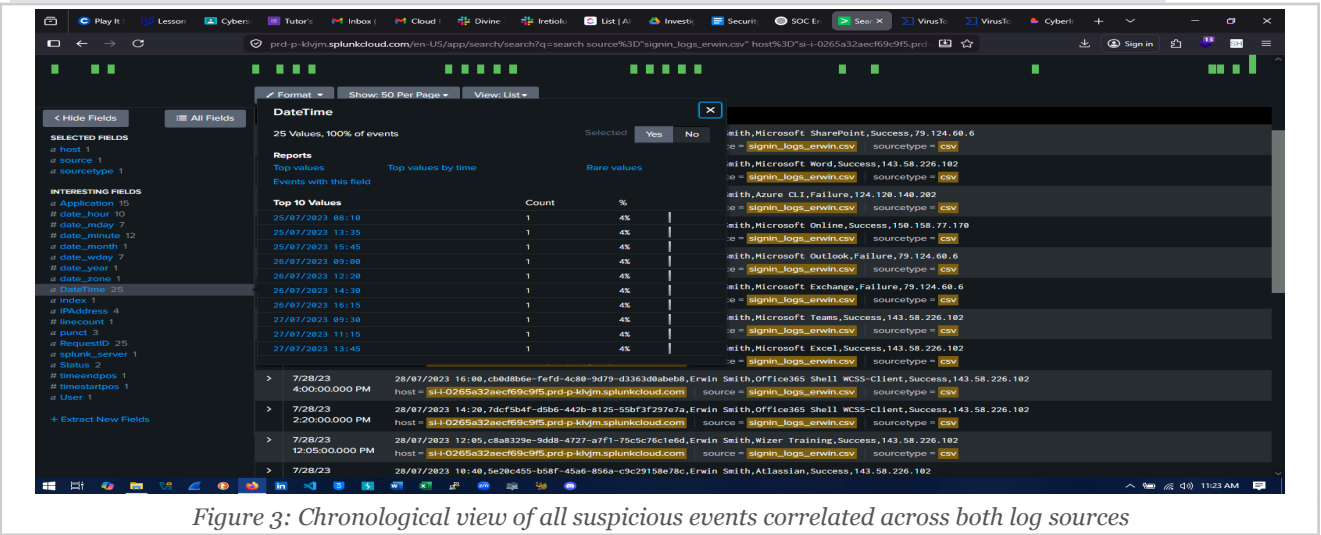


Figure 3: Chronological view of all suspicious events correlated across both log sources

The timeline demonstrates a clear progression from failed access attempts to successful authentication and data exfiltration. The legitimate user continued normal activity from the UK IP throughout, confirming the foreign logins were from a separate, unauthorised actor.

Threat Intelligence Enrichment

Each identified IP address was submitted to VirusTotal and cross-referenced against open-source threat intelligence feeds.

1.6 IP: 79.124.60.6 (Bulgaria)

VirusTotal returned a detection score of **1/95**. The IP is associated with "Laado-Raani-Private-Housing-Space", characteristic of a residential or VPN-type network. While the detection score is low, the behavioural evidence confirms this as the primary attack source.

1.7 IP: 150.158.77.170 (China)

VirusTotal returned a detection score of **3/95**, tagged for **phishing-related activity**. The IP is associated with Tencent (AS45090), a major Chinese cloud provider frequently leveraged by threat actors.

1.8 IP: 124.120.140.202 (Thailand)

VirusTotal returned a clean score of **0/95**. Associated with TRUEBB-NET, a Thai ISP. Only a single failed login was observed; assessed as low-risk.

1.9 IP: 143.58.226.102 (United Kingdom)

VirusTotal returned a clean score of **0/95**. Associated with UK-BCUBE. Confirmed as the legitimate user's IP address through consistent baseline activity.

Table 4: Threat Intelligence Summary

IP Address	Location	VT Score	Network / ASN	Assessment
79.124.60.6	Bulgaria	1/95	Laado-Raani Private Housing	Space —Confirmed--attacker
150.158.77.170	China	3/95	Tencent (AS45090)	Flagged — phishing
124.120.140.202	Thailand	0/95	TRUEBB-NET	Failed attempt only
143.58.226.102	United Kingdom	0/95	UK-BCUBE	Legitimate user

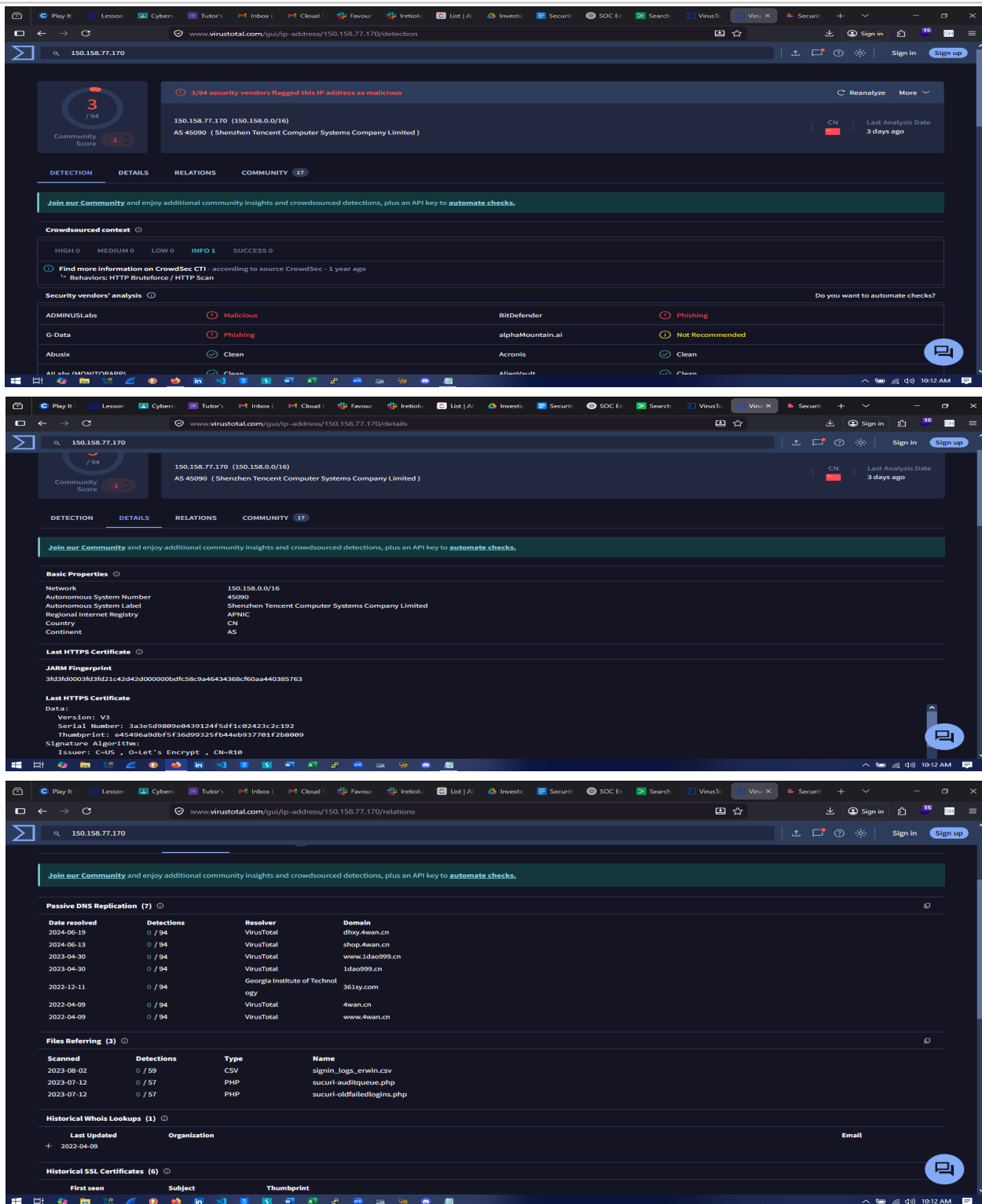


Figure 4: VirusTotal analysis results for each identified IP address

Initial Access Hypothesis

One of the observed IP addresses (150.158.77.170) has been flagged for phishing-related activity, raising the possibility that **phishing was used as an initial access vector** to harvest the user's credentials.

However, due to the **absence of email logs or user interaction data** within the scope of this investigation, the phishing hypothesis cannot be confirmed.

Based on available evidence, specifically the repeated failed login attempts from 79.124.60.6 followed by successful authentication, the attack most closely aligns with **brute-force or credential stuffing techniques** (MITRE ATT&CK: T1110).

Post-Compromise Activity Analysis

Following the successful authentication from the Bulgarian IP (79.124.60.6), activity logs reveal the attacker's actions within the compromised account.

1.10 Sensitive Document Access

On 31 July 2023 at 10:20, the attacker accessed an internal document via SharePoint:

- **File:** vulnerability_report_June2023.docx
- **Location:** https://sharepoint.com/Company/Docs/vulnerability_report_June2023.docx
- **Action:** File Access
- **IP:** 79.124.60.6 (Bulgaria)

This document likely contains information about the organization's security vulnerabilities. Access to this information could enable further targeted attacks.

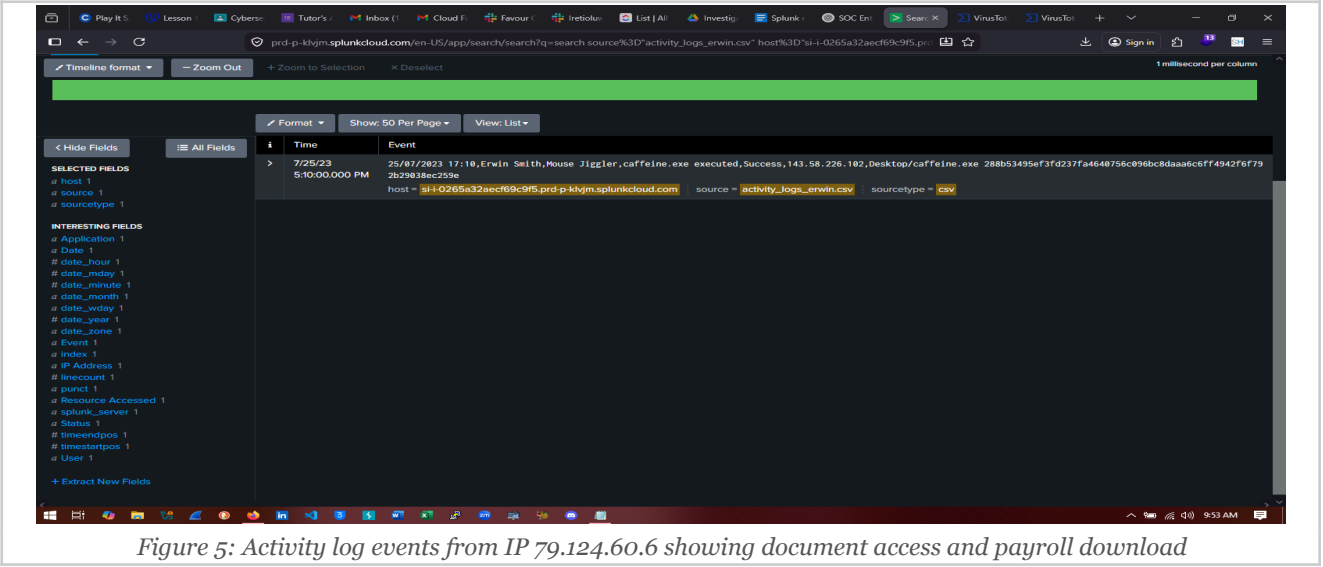
1.11 Sensitive Data Exfiltration

On 31 July 2023 at 17:10, the attacker downloaded a sensitive file from SharePoint:

- **File:** updated_payroll.xlsx
- **Location:** https://sharepoint.com/Company/Docs/updated_payroll.xlsx
- **Action:** File Download
- **IP:** 79.124.60.6 (Bulgaria)

This is the **most critical finding**. The event type "File Download" indicates data was actively transferred out of the organization's environment. A payroll file typically contains employee names, salaries, bank details, and National Insurance numbers. This constitutes **confirmed data exfiltration**.

1.12 False Positive: caffeine.exe (Mouse Jiggler)



Key Findings

Finding 1: Confirmed Account Compromise

The user account of Erwin Smith was compromised through a brute-force attack from IP 79.124.60.6 (Bulgaria). The attacker progressed from failed attempts to successful authentication on 31 July 2023, gaining access to Microsoft SharePoint.

Finding 2: Data Exfiltration Confirmed

The attacker accessed and downloaded sensitive data: **updated_payroll.xlsx** (employee financial information) and **vulnerability_report_June2023.docx** (internal security assessments). The download event confirms data left the organisation's control.

Finding 3: Multiple Foreign Access Points

Three distinct foreign IP addresses were identified. This suggests credentials may have been shared across multiple threat actors or accessed from different infrastructure points.

Finding 4: Concurrent Legitimate and Malicious Activity

The legitimate user continued normal activity from the UK IP throughout the compromise period, confirming the foreign logins were from a separate, unauthorised actor.

Indicators of Compromise (IoCs)

The following IoCs should be used for threat hunting, blocking, and monitoring:

Table 5: Indicators of Compromise

Type	Indicator	Description	Confidence
IP Address	79.124.60.6	Confirmed attacker — brute-force and data exfiltration	HIGH
IP Address	150.158.77.170	Phishing-flagged IP — successful activity	MEDIUM
IP Address	124.120.140.202	Failed login from Thailand — no access successful	LOW
File	updated_payroll.xlsx	Payroll data downloaded by attacker from sharepoint	CONFIRMED
File	vulnerability_report_June2023	vulnerability report accessed by attacker	CONFIRMED
Hash	288b53495ef3fd237fa464075false p6 f4942f6f792 29038ec259e	SHA-256 of caffeine.exe — benign	False positive)N/A

MITRE ATT&CK Framework Mapping

The observed techniques have been mapped to the MITRE ATT&CK framework:

Table 6: MITRE ATT&CK Mapping

Tactic	Technique ID	Technique Name	Evidence Observed
--------	--------------	----------------	-------------------

Initial Access	T1110	Brute Force	Multiple failed logins from 79.124.60.6 followed success
Persistence	T1078	Valid Accounts	Attacker used legitimate credentials to maintain
Collection	T1005	Data from Local System	Access to internal SharePoint documents
Exfiltration	T1041	Exfiltration Over Web Services	Download of payroll file via SharePoint

Recommended Response Actions

1.13 Immediate Actions (Within 24 Hours)

- **Password Reset** — Immediately reset Erwin Smith's account password
- **Session Termination** — Force logout of all active sessions
- **IP Blocking** — Block 79.124.60.6, 150.158.77.170, and 124.120.140.202 at the firewall
- **MFA Enforcement** — Enable Multi-Factor Authentication on the affected account

1.14 Short-Term Actions (Within 1 Week)

- **Data Exposure Assessment** — Assess the exfiltrated files for sensitivity and impact
- **Account Audit** — Review all account activity for 30 days before and after the incident
- **Lateral Movement Check** — Investigate whether the account was used to access other systems
- **Credential Review** — Check if credentials appear in known data breaches

1.15 Long-Term Actions (Within 1 Month)

- **Organisation-Wide MFA** — Enforce MFA for all accounts, prioritising privileged and finance accounts
- **Geo-Fencing Policies** — Restrict authentication from high-risk geographies
- **Impossible Travel Detection** — Deploy detection rules in Splunk for geographically impossible logins
- **Security Awareness Training** — Conduct phishing and credential security training

Table 7: Response Actions Summary

Priority	Action	Status	Owner
IMMEDIATE	Reset user password	Pending	SOC Team
IMMEDIATE	Force logout all sessions	Pending	SOC Team
IMMEDIATE	Block malicious IPs	Pending	Network Team
IMMEDIATE	Enable MFA for affected user	Pending	IT Admin
HIGH	Data exposure impact assessment	Pending	Data Protection Officer
HIGH	Review access logs for lateral movement	Pending	SOC Team
MEDIUM	Notify management and compliance	Pending	CISO / Legal
Priority	Action	Status	Owner

MEDIUM	Organisation-wide MFA rollout	Pending	IT Admin
MEDIUM	Implement geo-fencing policies	Pending	Security Engineering
MEDIUM	Security awareness training	Pending	HR / Security

13. Communication Strategy

1.16 Notification to Affected User

Erwin Smith should be immediately informed of the account compromise and instructed to:

- Reset all passwords, including accounts sharing similar credentials
- Review recent account activity for any unrecognised actions
- Report any suspicious emails or communications received recently
- Remain alert to potential follow-up phishing or social engineering attempts

1.17 Notification to Management

"A security incident has been confirmed involving unauthorized access to a user account. CyberInfiniti Ltd's investigation established that an external threat actor gained access through a brute-force attack and subsequently accessed and downloaded sensitive organisational data, including employee payroll information. Immediate containment measures have been implemented. A full impact assessment is underway to determine data exposure extent and regulatory reporting obligations under GDPR."

1.18 Stakeholders Requiring Notification

- **CISO / Head of Information Security** — Overall incident oversight and escalation
- **IT Management** — Technical containment and remediation
- **HR Department** — Payroll data compromised; affected employees may need notification
- **Data Protection Officer (DPO)** — GDPR implications and potential ICO notification
- **Legal / Compliance Team** — Regulatory obligations and potential legal exposure

Conclusion and Recommendations

This investigation by CyberInfiniti Ltd has conclusively established that the user account of Erwin Smith, Financial Analyst, was compromised through a brute-force attack originating from IP address 79.124.60.6 (Bulgaria). The attacker successfully authenticated on 31 July 2023 and accessed and downloaded sensitive organisational data from SharePoint.

The exfiltrated data includes employee payroll information (**updated_payroll.xlsx**) and an internal vulnerability assessment report (**vulnerability_report_June2023.docx**). The exposure of payroll data represents a significant risk to employee privacy and may trigger regulatory reporting obligations under the UK GDPR and Data Protection Act 2018. The exposure of the vulnerability report creates additional risk, as threat actors could leverage this information for further targeted attacks.

Additionally, a successful authentication from a phishing-flagged Chinese IP (150.158.77.170) was observed, though no post-authentication activity was recorded. This may indicate a secondary access vector or credential sharing among threat actors.

This has been classified as a **high-severity security incident** involving confirmed account compromise and data exfiltration. The following critical recommendations are made:

- Execute all immediate containment actions without delay (password reset, session termination, IP blocking)
- Enforce Multi-Factor Authentication across the organisation, prioritising high-risk accounts
- Conduct a comprehensive data exposure impact assessment for GDPR notification requirements
- Deploy geo-based login alerting and impossible travel detection rules within Splunk
- Implement conditional access policies to restrict authentication from high-risk geographies
- Review all accounts for signs of lateral movement or further compromise
- Initiate security awareness training focused on credential hygiene and phishing recognition

Continued vigilance and monitoring of the affected account and broader organisational infrastructure is essential. The lessons learned from this event should be incorporated into the organisation's security posture to prevent recurrence.